

Auditoria de Seguridad — AMS (Asset Management Software)

Fecha: 2026-03-19
Auditor: Claude Opus 4.6 (AI-assisted security audit)
Alcance: Proyecto completo AMS/OCP — backend, frontend, infraestructura Docker, configuracion
Stack: FastAPI 0.133.1 + SQLAlchemy 2.0.47 + SQLite/PostgreSQL (backend), React 19 + Vite 7 + Tailwind 4 (frontend), Docker Compose + Nginx
URL Produccion: 187.77.223.137:8030 (VPS)
Marcos de referencia: OWASP Top 10 2021, OWASP API Security Top 10 2023, ISO 27001:2022, Ley 21.663, Ley 19.628/21.719, NIST CSF 2.0

Resumen Ejecutivo

Severidad	Cantidad	Remediado	Pendiente
CRITICO	3	0	3
HIGH	8	0	8
MEDIUM	9	0	9
LOW	5	0	5
TOTAL	25	0	25

El proyecto tiene fundamentos de seguridad solidos (bcrypt, JWT validado, rate limiting, audit log, Pydantic schemas, ORM parametrizado, security headers). Sin embargo, existen **3 hallazgos criticos** que deben resolverse antes de produccion: credenciales expuestas en git, endpoints administrativos sin RBAC, y credenciales demo en produccion.

Controles Positivos Existentes

Control	Implementacion	Archivo
Password hashing	bcrypt con salt automatico	<code>api/services/auth_service.py:26-31</code>
JWT secret validation	Minimo 32 chars enforced at startup	<code>api/main.py:86-91</code>
Rate limiting global	120 req/min por IP	<code>api/main.py:54-82</code>
Rate limiting login	5 intentos / 5 min lockout	<code>api/services/auth_service.py:20-23</code>
Security headers	HSTS, X-Frame-Options DENY, nosniff, Referrer-Policy, Permissions-Policy	<code>api/main.py:39-51</code>
Input validation	Pydantic schemas con max_length en todos los campos	<code>api/schemas.py:9-13</code>
ORM parametrizado	SQLAlchemy ORM (no raw SQL con user input)	Todos los services
Audit logging	AuditLogModel con entity/action/user/IP/timestamp	<code>api/services/audit_service.py</code>
Health check	GET /health con verificacion de DB	<code>api/main.py:227-243</code>
File upload validation	Magic bytes + extension whitelist + size limit	<code>api/routers/imports.py:43-55</code>
Path traversal protection	<code>Path(filename).name</code> en endpoint de fotos	<code>api/routers/capture.py:22</code>
RBAC middleware	<code>require_role()</code> decorator disponible	<code>api/dependencies/auth.py:30-38</code>
Error sanitization global	Sin stack traces cuando DEBUG=false	<code>api/main.py:117-123</code>
Brute-force protection	Lockout in-memory por username	<code>api/services/auth_service.py:89-128</code>
Password policy	Min 8 chars + uppercase + digit	<code>api/schemas.py:458-469</code>
Nginx rate limiting	3r/m login, 10r/m admin, 10r/s API general	<code>nginx.conf</code>

Hallazgos de Seguridad

C1. Credenciales Expuestas en Repositorio Git

Severidad: CRITICO

OWASP: A02 Cryptographic Failures

ISO 27001: A.8.9, A.8.24

Archivo: `.env` (commiteado en git)

Descripcion:

El archivo `.env` esta commiteado en el repositorio con credenciales reales:

- **Línea 13:** `ANTHROPIC_API_KEY=sk-ant-api03-w3jF33Ey7kK-...` (API key completa)
- **Línea 31:** `JWT_SECRET_KEY=8JEF-AjTrMwWZBq64-bRJ2k0Zxvr40k0u1LKl-...` (secret completo)

Riesgo:

- Cualquier persona con acceso al repo puede forjar tokens JWT y suplantar cualquier usuario
- API key de Anthropic puede ser usada para generar costos no autorizados
- Aunque `.gitignore` incluye `.env`, el archivo ya fue commiteado al historial

Remediacion:

1. Revocar API key de Anthropic inmediatamente
2. Generar nuevo JWT_SECRET_KEY: `python -c "import secrets; print(secrets.token_urlsafe(64))"`
3. Limpiar historial git: `git filter-repo --path .env --invert-paths --force`
4. Force push a todos los remotes
5. Rotar todas las credenciales expuestas

Estado: PENDIENTE

C2. Endpoints Administrativos sin Control de Acceso

Severidad: CRITICO

OWASP: A01 Broken Access Control, API1 BOLA, API5 Broken Function Level Authorization

ISO 27001: A.5.15, A.8.3

Descripcion:

Multiples endpoints que realizan acciones privilegiadas no verifican el rol del usuario:

Endpoint	Archivo	Linea	Problema
PUT /work-requests/{id}/approve	work_requests.py	~202	Cualquier usuario autenticado puede aprobar WRs
PUT /work-requests/{id}/reject	work_requests.py	~214	Cualquier usuario puede rechazar WRs
PUT /work-requests/{id}/assign	work_requests.py	~250	Cualquier usuario puede reasignar trabajo
PUT /backlog/{id}/approve	backlog.py	~57	Cualquier usuario puede aprobar planes optimizados
PUT /work-packages/{id}/approve	work_packages.py	~70	Cualquier usuario puede aprobar work packages
GET /admin/agent-status	admin.py	~75	Sin autenticacion — endpoint publico
POST /admin/feedback	admin.py	~80	Sin autenticacion — spam/DoS posible

Riesgo: Escalacion de privilegios. Un tecnico puede aprobar sus propias solicitudes de trabajo, manipular el backlog y aprobar work packages sin supervision.

Remediacion:

```
# Agregar require_role() a cada endpoint
@router.put("/{id}/approve")
def approve_wr(id: str, user=Depends(require_role("admin", "manager", "planner")), ...):
```

Estado: PENDIENTE

C3. Credenciales Demo en Produccion

Severidad: CRITICO

OWASP: A07 Identification and Authentication Failures

ISO 27001: A.5.17, A.8.5

Descripcion:

Cuatro usuarios con password `password123` son auto-seeded en la base de datos:

Archivo: `api/seed.py:353-368`

```
default_users = [
  {"username": "admin", "password": "password123", "role": "admin"},
  {"username": "manager", "password": "password123", "role": "manager"},
  {"username": "planner", "password": "password123", "role": "planner"},
  {"username": "tecnico", "password": "password123", "role": "tecnico"},
]
```

Ademas, el frontend muestra estas credenciales en botones clickeables:

Archivo: `frontend/src/pages/Login.jsx:195-217`

```
onClick={() => { setUsername(d.user); setPassword('password123'); }}
```

Riesgo: Acceso completo al sistema con credenciales publicamente visibles.

Remediacion:

1. Generar passwords aleatorios en seed y mostrar una sola vez en consola
2. Forzar cambio de password en primer login
3. Remover botones de demo credentials del Login.jsx o limitar a entorno dev
4. Deshabilitar auto-seed en produccion

Estado: PENDIENTE

H1. Tokens JWT en localStorage (Vulnerable a XSS)

Severidad: HIGH

OWASP: A07, A03

Archivo: `frontend/src/api.js:5,12,24`

Descripcion:

```
localStorage.getItem('access_token') // linea 5
localStorage.getItem('api_key')      // linea 12
localStorage.getItem('refresh_token') // linea 24
```

localStorage es accesible desde cualquier JavaScript en la pagina. Si existe una vulnerabilidad XSS (actual o futura), un atacante puede robar todos los tokens.

Remediacion: Migrar a httpOnly secure cookies o implementar token rotation con refresh tokens de corta vida.

Estado: PENDIENTE

H2. Refresh Token sin Mecanismo de Revocacion

Severidad: HIGH

OWASP: A07

Archivo: `api/services/auth_service.py:40-45`

Descripcion: Refresh tokens tienen TTL de 7 dias sin blacklist. No hay forma de invalidar un token comprometido antes de su expiracion. El logout del frontend solo elimina el token localmente.

Remediacion: Implementar token blacklist en Redis o DB. Reducir TTL a 24h.

Estado: PENDIENTE

H3. CORS Permite localhost en Produccion

Severidad: HIGH

OWASP: A05 Security Misconfiguration

Archivo: `api/main.py:125-136` , `api/config.py:24`

Descripcion:

```
CORS_ORIGINS = "http://localhost:5173,http://localhost:8080,http://localhost"
```

En produccion, el codigo solo loguea un warning pero **no bloquea** origenes localhost.

Remediacion: Filtrar localhost/127.0.0.1 cuando DEBUG=false:

```
if not settings.DEBUG:
    allowed_origins = [o for o in allowed_origins if 'localhost' not in o and '127.0.0.1' not in o]
```

Estado: PENDIENTE

H4. Swagger/OpenAPI Expuesto Publicamente

Severidad: HIGH

OWASP: A05, API8, API9

Archivo: `nginx.conf` (bloque `/docs` y `/openapi.json`)

Descripcion: Los endpoints `/docs` y `/openapi.json` estan expuestos en produccion, revelando el esquema completo de la API, endpoints, parametros y modelos de datos.

Remediacion: Deshabilitar en produccion:

```
app = FastAPI(docs_url=None if not settings.DEBUG else "/docs",
              openapi_url=None if not settings.DEBUG else "/openapi.json")
```

Estado: PENDIENTE

H5. Dependencia xlsx con Vulnerabilidad de Prototype Pollution

Severidad: HIGH

OWASP: A06 Vulnerable Components

Archivo: frontend/package.json

Descripcion: El paquete `xlsx` (SheetJS) tiene vulnerabilidades conocidas de Prototype Pollution (GHSA-4r6h-8v6p-xvw6) y ReDoS (GHSA-5pgg-2g8v-p4x9). No hay fix disponible — el paquete esta abandonado en npm.

Remediacion: Reemplazar con `exceljs` o `xlsx-js-style`.

Estado: PENDIENTE

H6. Dependencias Python con CVEs Conocidos

Severidad: HIGH

OWASP: A06

Archivo: requirements.txt

Paquete	Version	CVE	Problema
python-multipart	0.0.20	CVE-2026-24486	Arbitrary File Write
PyJWT	2.9.0	CVE-2026-32597	Acepta header <code>crit</code> desconocido sin validar

Remediacion: Actualizar: `python-multipart>=0.0.24`, `PyJWT>=2.10.0`

Estado: PENDIENTE

H7. Enumeracion de Usuarios por Timing Attack

Severidad: HIGH

OWASP: A07, API2

Archivo: api/services/auth_service.py:112-128

Descripcion: Cuando el usuario no existe, la funcion retorna inmediatamente sin llamar `verify_password()`. La diferencia de tiempo (~200ms bcrypt vs ~0ms) permite determinar si un username existe.

Remediacion:

```
dummy_hash = bcrypt.hashpw(b"dummy", bcrypt.gensalt()).decode()
if not user or not user.is_active:
    verify_password(password, dummy_hash) # constant-time
    _record_failed_attempt(username)
    return None
```

Estado: PENDIENTE

H8. Sin 2FA/MFA para Roles Administrativos

Severidad: HIGH

OWASP: A07

ISO 27001: A.5.17

NIST: PR.AC-7

Descripcion: No existe soporte para autenticacion de dos factores. Cuentas admin protegidas solo por password.

Remediacion: Implementar TOTP (Google Authenticator) obligatorio para rol admin.

Estado: PENDIENTE

M1. Falta Content-Security-Policy Header

Severidad: MEDIUM

OWASP: A03, A05

Archivo: `api/main.py:39-51`

Descripcion: Todos los security headers estan presentes excepto CSP. Sin CSP, si se descubre un XSS, el payload se ejecuta sin restriccion.

Remediacion: Agregar al SecurityHeadersMiddleware:

```
response.headers["Content-Security-Policy"] = "default-src 'self'; script-src 'self'; style-src 'self';"
```

Estado: PENDIENTE

M2. Excepciones Filtran Detalles Internos

Severidad: MEDIUM

OWASP: A05

Archivos: `api/routers/imports.py:70` , `auth.py:71,85,92` , `ai_agents.py` , `media.py:60,102`

Description: Multiples routers usan `raise HTTPException(detail=str(e))` que envia el mensaje de excepcion interno al cliente, incluso cuando DEBUG=false. El handler global solo captura excepciones no-HTTP.

Remediacion: Usar mensajes genericos: `detail="Error procesando solicitud"` y loguear `str(e)` internamente.

Estado: PENDIENTE

M3. Rate Limiting In-Memory (No Distribuido)

Severidad: MEDIUM

OWASP: A04

Archivo: `api/main.py:54-82` , `api/services/auth_service.py:20-23`

Description: Rate limiting y logout de login usan diccionarios in-memory. Con multiples workers Gunicorn, un atacante puede hacer $5 * N_{workers}$ intentos antes del logout.

Remediacion: Usar Redis para estado compartido entre workers.

Estado: PENDIENTE

M4. HTTPS No Activo en Produccion

Severidad: MEDIUM

OWASP: A02

ISO 27001: A.8.24

Archivo: `nginx.conf:23-101` (bloque HTTPS comentado)

Description: La configuracion de nginx solo tiene HTTP activo (puerto 80). El bloque HTTPS con TLS esta comentado. HSTS header se agrega en backend pero sin HTTPS real no tiene efecto.

Remediacion: Activar bloque HTTPS en nginx con certificado Let's Encrypt.

Estado: PENDIENTE

M5. Docker sin security_opt ni Resource Limits

Severidad: MEDIUM

OWASP: A05

Archivo: `docker-compose.yml`

Description:

- Falta `security_opt: no-new-privileges:true` en todos los servicios

- No hay limites de CPU/memoria definidos
- Imagenes nginx:alpine sin version pinneada

Remediacion: Agregar a cada servicio:

```
security_opt:  
  - no-new-privileges:true  
deploy:  
  resources:  
    limits:  
      memory: 1G  
      cpus: '2'
```

Estado: PENDIENTE

M6. Sin Password Reset

Severidad: MEDIUM

OWASP: A07

Archivo: `api/routers/auth.py`

Descripcion: No existe endpoint de recuperacion de password. Si un usuario pierde su password, solo un admin puede intervenir.

Remediacion: Implementar forgot-password con token temporal (15 min TTL) enviado por email.

Estado: PENDIENTE

M7. Fotos Publicas sin Autenticacion

Severidad: MEDIUM

OWASP: A01

Archivo: `api/routers/capture.py:21-33`

Descripcion: El endpoint `GET /capture/photos/{filename}` es publico. Si los nombres de archivo (UUIDs) son predecibles o enumerables, fotos de cualquier usuario pueden ser accedidas.

Remediacion: Agregar autenticacion o usar signed URLs con TTL.

Estado: PENDIENTE

M8. Sin Limite de Body Size Explicito en FastAPI

Severidad: MEDIUM

OWASP: API4

Archivo: `api/main.py`

Descripcion: No hay limite explicito de body size en FastAPI. Nginx limita a 50MB pero FastAPI acepta el default (~100MB de Starlette).

Remediacion: Agregar middleware de body size limit o configurar en Gunicorn.

Estado: PENDIENTE

M9. f-string en SQL de Migraciones

Severidad: MEDIUM

OWASP: A03

Archivo: `api/database/connection.py:79-82`

Descripcion:

```
conn.execute(text(f"ALTER TABLE {table} ADD COLUMN {column} {col_type}{default_clause}"))
```

Usa f-string interpolation en SQL. Actualmente los valores son hardcoded (no user input), pero el patron es vulnerable si se modifica.

Remediacion: Usar DDL de SQLAlchemy o migrar a Alembic.

Estado: PENDIENTE

L1. innerHTML en Archivos Template (Vite)

Severidad: LOW

OWASP: A03

Archivos: `frontend/src/counter.ts:5`, `frontend/src/main.ts:6`

Descripcion: Archivos template de Vite (no usados en produccion) usan `innerHTML` con template literals.

Remediacion: Eliminar archivos template no usados.

Estado: PENDIENTE

L2. .gitignore Falta Patrones de Certificados

Severidad: LOW

Archivo: `.gitignore`

Descripcion: Falta excluir: `*.pem`, `*.key`, `*.crt`, `*.p12`, `credentials.json`, `service-account*.json`

Remediacion: Agregar patrones al `.gitignore`.

Estado: PENDIENTE

L3. Login Error Message Diferenciado

Severidad: LOW

OWASP: API2

Archivo: `api/services/auth_service.py`

Descripcion: El mensaje de error no diferencia entre usuario no encontrado y password incorrecto (correcto — "Credenciales invalidas"). Pero el timing attack (H7) permite enumeracion igualmente.

Estado: INFORMATIVO — ya implementado correctamente en mensaje, pero vulnerable por timing.

L4. Audit Log No Registra Eventos de Auth

Severidad: LOW

OWASP: A09

Archivo: `api/services/audit_service.py`

Descripcion: El sistema de audit log existe pero no registra eventos de autenticacion (login exitos/fallidos, cambios de password, cambios de rol). Solo se loguean con `logger.warning()` a stdout.

Remediacion: Agregar `log_action()` calls en `auth_service` para persistir en DB.

Estado: PENDIENTE

L5. SQLite como Default de Produccion

Severidad: LOW

Archivo: `api/config.py:17`

Descripcion: `DATABASE_URL` defaults a `sqlite:///./ocp_maintenance.db`. Si no se configura la variable de entorno, produccion usaria SQLite.

Remediacion: Fail startup si `DATABASE_URL` no esta configurado y `DEBUG=false`.

Estado: PENDIENTE

Cumplimiento Normativo

OWASP Top 10 2021

ID	Vulnerabilidad	Estado	Hallazgos
A01	Broken Access Control	HALLAZGO	C2 (5 endpoints sin RBAC), M7 (fotos publicas)
A02	Cryptographic Failures	HALLAZGO	C1 (secrets en git), M4 (sin HTTPS)
A03	Injection (SQL/XSS)	OK	ORM parametrizado, React auto-escape, falta CSP (M1)
A04	Insecure Design	OK	Rate limiting, lockout, Pydantic validation
A05	Security Misconfiguration	HALLAZGO	H3 (CORS), H4 (Swagger), M2 (error details), M5 (Docker)
A06	Vulnerable Components	HALLAZGO	H5 (xlsx), H6 (python-multipart, PyJWT)
A07	Auth Failures	HALLAZGO	C3 (demo creds), H1 (localStorage), H7 (timing), H8 (no 2FA)
A08	Data Integrity	OK	Pydantic validation, JWT firmado
A09	Logging Failures	HALLAZGO	L4 (auth events no persistidos)
A10	SSRF	OK	No se detectaron vectores SSRF

OWASP API Security Top 10 2023

ID	Vulnerabilidad	Estado
API1	BOLA	HALLAZGO — C2
API2	Broken Auth	OK (bcrypt + lockout) pero timing attack H7
API3	Broken Property Auth	OK (Pydantic DTOs)
API4	Unrestricted Resource	OK (rate limiting, limites de archivo)
API5	Broken Function Auth	HALLAZGO — C2 (endpoints sin role check)
API6	Unrestricted Business Flows	OK
API7	SSRF	OK
API8	Security Misconfiguration	HALLAZGO — H4 (Swagger expuesto)
API9	Improper Inventory	HALLAZGO — H4 (OpenAPI publico)
API10	Unsafe API Consumption	OK

ISO 27001:2022

Control	Requisito	Estado
A.5.1	Politica de seguridad documentada	FALTA
A.5.9	Inventario de activos	FALTA
A.5.15	Control de acceso (RBAC)	PARCIAL — middleware existe pero no aplicado en todos los endpoints
A.5.17	Autenticacion segura	PARCIAL — bcrypt OK, falta 2FA
A.5.24-27	Plan de respuesta a incidentes	FALTA
A.8.3	Restriccion de acceso a datos	HALLAZGO — C2
A.8.5	Autenticacion segura	PARCIAL — bcrypt OK, falta 2FA, timing attack
A.8.7	Validacion de archivos	OK — magic bytes + whitelist
A.8.8	Vulnerabilidades tecnicas	HALLAZGO — H5, H6
A.8.9	Gestion de configuracion	HALLAZGO — C1 (secrets en git)
A.8.10	Eliminacion de datos	FALTA — no hay soft-delete ni retencion definida
A.8.13	Backup y recuperacion	FALTA — no documentado
A.8.15	Logging de seguridad	PARCIAL — audit log existe, falta auth events
A.8.16	Monitoreo	OK — health check implementado
A.8.24	Criptografia	PARCIAL — bcrypt OK, falta HTTPS real
A.8.25	Ciclo de desarrollo seguro	FALTA — no hay CI/CD con security checks
A.8.26	Seguridad en requisitos	OK — Pydantic validation
A.14.2	Seguridad en desarrollo	FALTA — no hay pipeline de seguridad
A.17.1	Plan de continuidad	FALTA

Ley 19.628 / 21.719 (Proteccion de Datos Personales)

Requisito	Estado
Politica de privacidad publica	FALTA
Inventario de datos personales (PII)	FALTA
Derechos ARCO implementados	FALTA
Derecho de acceso (exportacion datos)	FALTA
Derecho de rectificacion (editar perfil)	PARCIAL — PUT /auth/me existe
Derecho de cancelacion (eliminar cuenta)	FALTA
Derecho de portabilidad (JSON export)	FALTA
Consentimiento informado	FALTA
Retencion de datos con purga automatica	FALTA
Transferencias internacionales documentadas	FALTA (usa Anthropic API → USA)
Enlace a privacy policy en login	FALTA

Ley 21.663 (Marco de Ciberseguridad Chile)

Requisito	Estado
Medidas tecnicas adecuadas	PARCIAL
Plan de notificacion de brechas (72h)	FALTA
Registro de incidentes (3 anos)	FALTA
Evaluacion de riesgos documentada	FALTA
Gestion de vulnerabilidades	FALTA — no hay proceso periodico
Monitoreo y deteccion	PARCIAL — rate limiting + lockout

Documentacion ISO 27001 Faltante

Los siguientes documentos son requeridos para cumplimiento ISO 27001 y **no existen**:

```
docs/
├─ SECURITY-POLICY.md           # A.5.1 – Politica de seguridad
├─ ACCESS-CONTROL-POLICY.md    # A.5.15 – Politica de control de acceso
├─ PRIVACY-POLICY.md          # A.5.34 – Politica de privacidad (Ley 19.628)
├─ ASSET-INVENTORY.md         # A.5.9 – Inventario de activos
├─ INCIDENT-RESPONSE-PLAN.md   # A.5.24 – Plan de respuesta a incidentes
├─ BACKUP-RECOVERY-PLAN.md     # A.17.1 – Plan de continuidad
├─ DATA-CLASSIFICATION.md     # A.5.12 – Clasificacion de informacion
├─ DATA-RETENTION-POLICY.md   # A.8.10 – Politica de retencion
└─ RISK-ASSESSMENT.md         # A.5.7 – Evaluacion de riesgos
```

Plan de Remediacion Priorizado

INMEDIATO (Antes de produccion)

#	Accion	Severidad	Esfuerzo
1	Revocar API key de Anthropic y generar nueva	CRITICO	5 min
2	Rotar JWT_SECRET_KEY y forzar re-login	CRITICO	10 min
3	Limpiar .env del historial git con git-filter-repo	CRITICO	30 min
4	Agregar require_role() a 5 endpoints sin RBAC	CRITICO	1h
5	Agregar auth a /admin/agent-status y /admin/feedback	CRITICO	15 min
6	Remover/gatear credenciales demo en Login.jsx	CRITICO	30 min
7	Randomizar passwords de seed o deshabilitar auto-seed	CRITICO	30 min

ESTA SEMANA

#	Accion	Severidad	Esfuerzo
8	Agregar Content-Security-Policy header	MEDIUM	30 min
9	Bloquear localhost en CORS cuando DEBUG=false	HIGH	15 min
10	Deshabilitar Swagger/OpenAPI en produccion	HIGH	15 min
11	Actualizar python-multipart y PyJWT	HIGH	15 min
12	Reemplazar xlsx por exceljs	HIGH	1h
13	Sanitizar detail=str(e) en routers	MEDIUM	1h
14	Fix timing attack en authenticate_user()	HIGH	15 min

ESTE MES

#	Accion	Severidad	Esfuerzo
15	Activar HTTPS con Let's Encrypt en nginx	MEDIUM	2h
16	Implementar token blacklist/revocacion	HIGH	4h
17	Migrar tokens de localStorage a httpOnly cookies	HIGH	8h
18	Agregar security_opt y resource limits a Docker	MEDIUM	30 min
19	Implementar 2FA/TOTP para admin	HIGH	8h
20	Implementar password reset por email	MEDIUM	4h
21	Agregar auth events al audit log	LOW	2h
22	Agregar .pem/.key/.crt a .gitignore	LOW	5 min
23	Crear documentacion ISO 27001 (9 documentos)	MEDIUM	16h
24	Implementar derechos ARCO (endpoints)	MEDIUM	8h
25	Crear politica de privacidad publica	MEDIUM	4h

Checklist Final

Seguridad Tecnica

- [x] Passwords hasheados con bcrypt
- [x] Rate limiting en login y APIs
- [x] Security headers (HSTS, X-Frame-Options, nosniff, Referrer-Policy)
- [x] ORM parametrizado (no SQL injection)
- [x] Uploads validados por magic bytes
- [x] Health checks implementados
- [x] Input validation con Pydantic schemas
- [x] Path traversal prevention en photos
- [x] Error sanitization global (cuando DEBUG=false)
- [] **No hay secrets en codigo ni historial git** ← CRITICO
- [] **RBAC en TODOS los endpoints** ← CRITICO
- [] **Credenciales demo removidas** ← CRITICO
- [] HTTPS forzado
- [] CSP header

- ☐ CORS restrictivo en produccion
- ☐ Swagger deshabilitado en produccion
- ☐ 2FA para admins
- ☐ Dependencias sin vulns criticas
- ☐ Token revocation

CI/CD

- ☐ Pipeline con escaneo de secretos
- ☐ Pipeline con lint de seguridad
- ☐ Pipeline con audit de dependencias
- ☐ Pipeline con tests automatizados

Documentacion (ISO 27001)

- ☐ Politica de seguridad
- ☐ Inventario de activos
- ☐ Plan de respuesta a incidentes
- ☐ Plan de continuidad
- ☐ Seguridad en desarrollo

Ley 19.628/21.719

- ☐ Inventario de datos personales
- ☐ Politica de privacidad publica
- ☐ Derechos ARCO implementados
- ☐ Retencion de datos con purga
- ☐ Transferencias internacionales documentadas

Ley 21.663

- ☐ Plan de notificacion de brechas (72h)
- ☐ Registro de incidentes (3 anos)
- ☐ Evaluacion de riesgos documentada

Auditoria generada el 2026-03-19 siguiendo GUIA-AUDITORIA-SEGURIDAD.md (CSF-001 v3.0)

Herramienta: Claude Opus 4.6 — analisis estatico de codigo fuente + verificacion de endpoints en produccion